In the Natter and Moderation APIs, a user makes a claim of identity in two places:

1. In the Create Space operation, the request includes an “owner” field that identifies the user creating the space.
2. In the Post Message operation, the user identifies themselves in the “author” field.

The operations to read messages currently don’t identify who is asking for those messages at all, meaning that we can’t tell if they should have access. You’ll correct both problems by introducing authentication. As I mentioned in section 3.3 on rate-limiting, requiring authentication for requests also reduces the risk of DoS attacks.

3.3.1 HTTP Basic authentication

There are many ways of authenticating a user, but one of the most widespread is simple username and password authentication. In a web application with a user interface, we might implement this by presenting the user with a form to enter their username and password. An API is not responsible for rendering a UI, so we can instead use the standard HTTP Basic authentication mechanism to prompt for a password in a way that doesn’t depend on any UI. This is a simple standard scheme, specified in RFC 7617 (https://tools.ietf.org/html/rfc7617), in which the username and password are encoded (using the Base64 encoding, see sidebar) and sent in a header. An example of a Basic authentication header for the username `"demo"` and password `"changeit"` is as follows: